ÜBUNG 01

Rechnersicherheit

IT-SICHERHEIT / SEMESTER 3

1

AGENDA

01 NUTZUNG SICHERER QUELLEN FÜR HARD- UND SOFTWARE

02 VERWENDUNG GETRENNTER STANDARDBENUTZERKONTEN UND ADMINISTRATORENKONTEN

03 VERWENDUNG ANGEMESSENER KENNWORTRICHTLINIEN

04 SICHERES SPEICHERN VON KENNWÖRTERN

05 KEINE WIEDERVERWENDUNG VON KENNWÖRTERN

06 REGELMÄßIGE AKTUALISIERUNG DER FIRMWARE, DES BETRIEBSSYSTEMS UND INSTALLIERTER APPLIKATIONEN

07 INSTALLATION AUSSCHLIEßLICH NOTWENDIGER APPLIKATIONEN UND BETRIEBSSYSTEM-KOMPONENTEN

08 VERWENDUNG VON FESTPLATTENVERSCHLÜSSELUNG

tgm

2

01

Konfigurations-empfehlungen

3

IT-SICHERHEIT / SEMESTER 3

[01] Nutzung sicherer Quellen für Hard- und Software

- **Eingesetzte Hardware sollte nur aus vertrauenswürdigen Quellen**, idealerweise über den Hersteller, bezogen werden. Dies gilt nicht nur für das Endgerät, sondern auch für Hardware, die an dieses angeschlossen wird.
- **Software, die installiert wird, sollte nur aus vertrauenswürdigen Quellen bezogen werden**. Wenn möglich, sollte Software über Bereitstellungen des Unternehmens bzw. der Organisation bezogen werden. Ist dies nicht möglich, sollte kommerzielle Software über den Fachhandel oder den Hersteller direkt akquiriert werden.
- Wird **Open Source Software** installiert oder Open Source Code (z. B. Skripte) ausgeführt, sollte der Entwickler identifiziert und die Software oder **Skripte aus Quellen bezogen werden, die mit dem Entwickler assoziiert sind**, wie z. B. dem zugehörigen GitHub Repository.
- Wird Software oder **generell Code aus Online-Quellen** heruntergeladen, sollte die Integrität der Daten geprüft werden. Dies kann durch eine **Verifikation mit einem vom Hersteller bereitgestellten Hash-Wert** erfolgen oder durch Prüfung einer vorhandenen digitalen Signatur hinsichtlich Integrität und Authentizität des Herausgebers.
- **Software sollte, wann immer möglich, über einen sicheren und verschlüsselten Kanal übertragen werden**, bevor diese auf einem System zum Einsatz kommt. Dies ist vor allem zu beachten, wenn Daten über das Internet transferiert werden. Ziel ist es hierbei sog. Man-in-the-Middle-Angriffe zu verhindern und eine Authentizitätsprüfung des Herausgebers zu ermöglichen, z.B. durch Einsatz von Transport Layer Security (TLS).

tgm [Quelle: Konfigurationsempfehlungen zur Härtung von Windows 10 mit Bordmitteln, BFI V1.0, 2021]

4

IT-SICHERHEIT / SEMESTER 3

[02] Verwendung getrennter Standardbenutzerkonten und Administratorenkonten

- **Die typischen Tätigkeiten eines Standardbenutzers** (z. B. Aufrufen von Webseiten, Abrufen von E-Mails, Bearbeiten von Dokumenten) bringen ein **deutlich höheres Risiko** für eine Kompromittierung mit sich, als es die Tätigkeiten eines Administrators tun.
- Es sollten **mindestens zwei unterschiedliche Konten** angelegt werden. Ein Konto, welches über keine besonderen Berechtigungen verfügt und somit aus Angreifersicht wenig lohnend ist, sowie ein administratives Konto, dem die Berechtigungen zugewiesen werden, die für Administrationstätigkeiten notwendig sind.
- Das **Standardbenutzerkonto** wird daraufhin für die **initiale Anmeldung und unprivilegierte Tätigkeiten** genutzt
- während das **administrative Benutzerkonto** nur zum Einsatz kommt, wenn **höhere Berechtigungen** genutzt werden müssen. Dies senkt die Wahrscheinlichkeit einer erfolgreichen Kompromittierung von Administratorenkonten und stellt eine zusätzliche Hürde für einen Angreifer dar.

Hinweis: Windows Benutzerkontensteuerung begünstigt dies, da bei Aktionen, die erhöhte Privilegien erfordern, automatisch nach Zugangsdaten eines administrativen Benutzerkontos gefragt wird, wenn der angemeldete Benutzer diese nicht bereits besitzt.

tgm [Quelle: Konfigurationsempfehlungen zur Härtung von Windows 10 mit Bordmitteln, BFI V1.0, 2021]

5

IT-SICHERHEIT / SEMESTER 3

[03] Verwendung angemessener Kennwortrichtlinien

- **Einfache Kennwörter** können von einem Angreifer mittels einer Passwort-Attacke (z. B. durch Brechen eines Hash-Wertes, um das zugehörige Klartext-Kennwort zu erhalten)
  - **berechnet** oder manchmal sogar
  - **erraten** werden (z. B. durch sog. Password Spraying, bei dem dasselbe Kennwort für alle Benutzer einer Umgebung zur erfolgreichen Authentifizierung getestet wird).
- Kennworts Anforderungen sind zu erfüllen, die eine Berechnung (oder das Erraten) des Kennworts deutlich erschweren.
- **Die Länge ist ausschlaggebender für die Passwort-Qualität als die Komplexität und durch diese zusätzliche Länge muss das Kennwort seltener geändert werden.**
- **Das Erhöhen der Passwort-Komplexität bei geringer Länge würde hingegen die Kennwort-Qualität nur geringfügig erhöhen.**

tgm [Quelle: Konfigurationsempfehlungen zur Härtung von Windows 10 mit Bordmitteln, BFI V1.0, 2021]

6

IT-SICHERHEIT / SEMESTER 3

[04] Sicheres Speichern von Kennwörtern

- In **Klartext auf dem System gespeicherte Passwörter** (Textdateien, Skripte, Browser, ...) können von einem Angreifer, der über die Berechtigungen des angemeldeten Benutzers verfügt, auf einfache Weise ausgelesen werden.
- In einem **Passwort-Manager** können Passwörter verschlüsselt und vor unautorisiertem Zugriff geschützt abgelegt werden.
  - Nach der Installation erstellt der Benutzer eine Passwortdatenbank und wählt ein angemessen sicheres Masterpasswort (in Übereinstimmung mit einer vorher definierten Richtlinie).
  - In der Passwortdatenbank sollten dann alle Passwörter hinterlegt werden, die der Benutzer zum Zugriff auf Webseiten, Freigaben, Applikationen etc. benötigt.
  - Diese Passwörter sollen möglichst vom Passwort-Manager generiert werden und somit einzigartig sein.
  - Durch die Eingabe des Masterpassworts kann auf die Passwörter in der verschlüsselten Datenbankdatei zugegriffen werden.

tgm [Quelle: Konfigurationsempfehlungen zur Härtung von Windows 10 mit Bordmitteln, BFI V1.0, 2021]

IT-SICHERHEIT / SEMESTER 3

[05] Keine Wiederverwendung von Kennwörtern

- **Wird dasselbe Kennwort für unterschiedliche Zwecke (z. B. Anwendungen, Computersysteme, Webseiten) verwendet, kann dieses auch an mehreren Stellen durch einen Angreifer kompromittiert werden.**
  - Eine angreifbare Stelle reicht dabei aus, um anschließend Zugriff auf weitere, unabhängige Dienste zu erlangen.
- Ein Passwort-Manager gewährleistet in diesem Fall nicht nur die sichere Verwahrung einer Vielzahl von Kennwörtern sondern kann auch genutzt werden, um zufällige und einzigartige Kennwörter pro Anwendung/Dienst zu generieren und abzuspeichern.
- **Für jeden Dienst, der ein Passwort erfordert, sollte der Benutzer somit ein eigenes Kennwort erstellen** und im Passwort-Manager sicher abspeichern.
  - Dies gilt auch für unterschiedliche Benutzerkonten (z. B. Domänenbenutzerkonten), die von derselben Person verwendet werden.

tgm [Quelle: Konfigurationsempfehlungen zur Härtung von Windows 10 mit Bordmitteln, BFI V1.0, 2021]

IT-SICHERHEIT / SEMESTER 3

[06] Regelmäßige Aktualisierung der Firmware, des Betriebssystems und installierter Applikationen

- Die Firmware des Geräts sollte immer auf einem aktuellen Stand gehalten werden. Dafür ist es notwendig in regelmäßigen Abständen zu prüfen, ob ein neues Update vom Hersteller veröffentlich wurde.
- Zu dem Updateprozess sollte ebenfalls eine **Überprüfung des hinterlegten kryptographischen Schlüsselmaterials bzw. der Zertifikate** gehören, welche festgelegen, welche Firmware(-Updates) und Betriebssystem-Loader auf dem Gerät ausgeführt werden können (Secure Boot).
- **Updates, Patches und Hotfixes für Betriebssysteme** und Anwendungen von Microsoft schnellstmöglich nach Veröffentlichung über die Windows-Update Funktionalität des Betriebssystems installiert werden.
- In verwalteten Domänen-Umgebungen kann zudem ein sogenannter **Windows Server Update Service** (WSUS) die Updates zentralisiert bereitstellen, um kontrollieren zu können, welche Systeme welche Updates erhalten.
- Standardisierte Anwendungen in einer verwalteten Umgebung (Browser, E-Mail-Programm, Dokumentenverarbeitung etc.) sollten durch **eine zentralisierte Patch-Management-Lösung** so bald wie möglich nach Veröffentlichung aktualisiert werden.
- Auf Einzelrechnern sollte in **regelmäßigen Abständen manuell geprüft werden**, ob neue Updates zur Verfügung stehen. Hierbei gibt es häufig keine definierten Zyklen.

tgm [Quelle: Konfigurationsempfehlungen zur Härtung von Windows 10 mit Bordmitteln, BFI V1.0, 2021]

IT-SICHERHEIT / SEMESTER 3

[07] Installation ausschließlich notwendiger Applikationen und Betriebssystem-Komponenten

- **Jede zusätzliche Software-Komponente bietet eine zusätzliche Angriffsfläche** und muss in regelmäßigen Zyklen (teils manuell) aktualisiert werden.
- Daher sollten nur Anwendungen und Betriebssystemkomponenten installiert werden, die **für die tatsächliche Tätigkeit des Benutzers** bzw. für den Betrieb des Systems benötigt werden.
- **Initial sollten vorinstallierte, aber nicht benötigte Anwendungen und Windows-Komponenten deinstalliert werden** oder wenn dies nicht möglich ist, zumindest deaktiviert werden (wie z. B. bei Windows-Diensten).
- Zusätzlich sollten in **regelmäßigen Abständen die momentan installierten Anwendungen evaluiert werden** und bei fehlender Notwendigkeit entfernt werden.

tgm [Quelle: Konfigurationsempfehlungen zur Härtung von Windows 10 mit Bordmitteln, BFI V1.0, 2021]

IT-SICHERHEIT / SEMESTER 3

[08] Verwendung von Festplattenverschlüsselung

- Um die **Vertraulichkeit von Daten**, die im Dateisystem des Betriebssystems abgespeichert sind, zu sichern und **nicht autorisierten Modifikationen von Daten entgegenzuwirken**, sollte eine Software-Lösung zur Festplattenverschlüsselung eingesetzt werden.
- Dies ist vor allem dann relevant, wenn die **physische Sicherheit nicht mehr gewährleistet werden kann**, z. B. im Falle eines Diebstahls des Geräts.
- Das Verschlüsselungsprogramm, sollte **vor dem Start des Betriebssystems, eine Benutzer-Authentisierung** durchführen (die sog. Prä-Boot-Authentisierung), um zu verhindern, dass Teile des kryptographischen Materials zur Entschlüsselung der Festplatte in den Arbeitsspeicher geladen und dort potenziell ausgelesen werden können.
- Der eingesetzte Verschlüsselungsschlüssel **sollte zufällig generiert sein und sicher aufbewahrt werden**.
- Vor Aktivierung der Festplattenverschlüsselung sollte zudem ein **Konzept zur Sicherung bzw. Wiederherstellung** entwickelt werden, um den vollständigen Verlust der lokalen Daten zu verhindern, falls der Entschlüsselungsschlüssel verloren wird.

tgm [Quelle: Konfigurationsempfehlungen zur Härtung von Windows 10 mit Bordmitteln, BFI V1.0, 2021]

11

02

Übung

12

IT-SICHERHEIT / SEMESTER 3

Übung 01 – Rechnersicherheit

ZIELE

- Den eigenen Rechner untersuchen mit einer Kombination aus integrierten Tools, Microsoft-Utilities und Drittanbieter-Software.

VORAUSSETZUNGEN

- Sysinternals Suite installiert
- Attack Surface Analyzer 2.0 installiert

BEWERTUNG

- GK: max. 2 Punkte
- EK: max. 1 Punkt

DETAILLIERTE AUFGABENBESCHREIBUNG & FRAGESTELLUNGEN

- Integrierte Windows Tools nutzen
- Microsoft Attach Surface Analyzer
- PowerShell Anwendung
- Passwortmanager
- Tools und Logs analysieren
- EK: Zentrale Sicherheitskonzepte von Windows 11 recherchieren

ABGABE

- GK – Den eigenen Rechner untersucht
- GK – zusätzlich alle Fragestellungen beantwortet
- EK – Erweiterte Security Mechanismen erarbeitet
- Zusammenfassung auf einem Grafiz - Abgabe als PDF auf Moodle

tgm

13

BACKUP

14

NETZWERKTECHNIK / SEMESTER 3

Feedback zu bereitgestellten Unterlagen erwünscht

Ich möchte unsere Unterlagen stetig verbessern – und dafür brauchen wir eure Meinung!

👉 Was war für euch besonders hilfreich?

👉 Was hat euch gefehlt oder war unklar?

Online Excel:

https://1drv.ms/x/c/e9fa3e1f655a10ff/ESzSp-Rhhq1FmOFlM4Yji58BSv38JUaGNTdpTFe2gYv9aA?e=4gs4do

Teile deine Gedanken mit uns – kurz, ehrlich und direkt.

Nur so können wir besser werden.

Danke für deine Unterstützung!

Rückmeldungen fließen auch in die Mitarbeitsbeurteilung ein.

IT-SICHERHEIT / SEMESTER 3

Cyber Sicherheit

Das Lehrbuch für Konzepte, Prinzipien, Mechanismen, Architekturen und Eigenschaften von Cyber-Sicherheitssystemen in der Digitalisierung

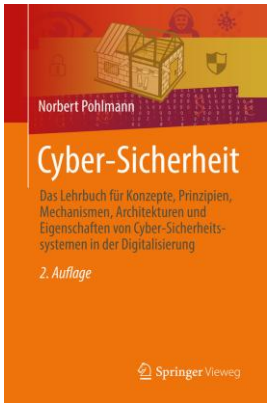
Von: Pohlmann, Norbert

ISBN/EAN: 978-3-658-36242-3

Verlag: Springer Fachmedien Wiesbaden

Erscheinungsdatum: 04.05.2022

Auflage: 2. Auflage 2022



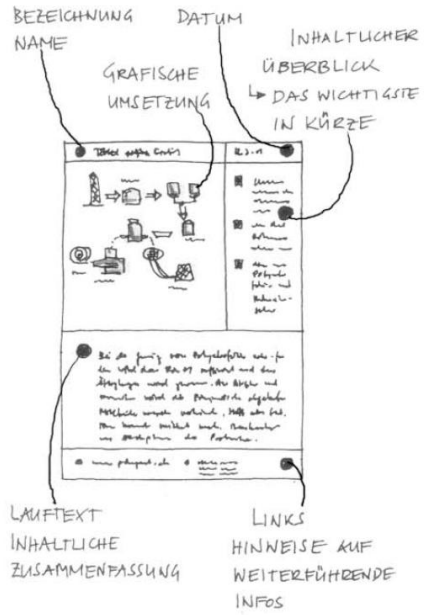
NETZWERKTECHNIK / SEMESTER 3

Graf-iz

Ein Graf-iz enthält immer

- eine Titelzeile mit Datum,
- eine grafische Darstellung des Sachverhalts (Zeichnung, Schaubild, Diagramm etc.),
- eine stichpunktartige Übersicht der zentralen Informationen,
- einen kurzen Fließtext für weitergehende Notizen und
- eine Zeile für Quellen.
- Links:
  - So geht's: joe-beilage-okt20-infoblatt.pdf
  - Word Template: Grafiz | Methodenwürfel RITA

Microsoft Word Document



tgm